
DATA PROTECTION & PRIVACY POLICY

Policy reference : POL-PRIV-001
Title : Data Protection & Privacy Policy
Document type : internal-policy
Owner : Northgate Systems Ltd – Legal / DPO
Status : Approved – current

PURPOSE OF THIS DOCUMENT

Northgate's data protection policy governing personal data processed as controller and processor: DPA terms, lawful basis, transfers, retention, breach handling and DPIAs. The most-cited policy in the contract corpus.

RELATED LEGISLATION & STANDARDS

- UK GDPR (Arts. 5, 6, 9, 28, 33, 35, 46)
- Data Protection Act 2018
- Data (Use and Access) Act 2025
- PECR 2003
- Commission Implementing Decision (EU) 2021/914 (SCCs)
- EU GDPR, Art. 28
- CCPA 2018 (as amended by CPRA 2020)

CONTENTS

1. Purpose, Scope & Roles
2. Lawful Basis & Marketing Consent
3. Processor Terms & DPA Requirements
4. Sub-Processors
5. International Transfers & Safeguards
6. Data Retention & Deletion
7. Special Category & High-Risk Data; DPIAs
8. Personal Data Breach Notification
9. Data Subject Rights & Audit Cooperation
10. Records of Processing & Accountability
11. Privacy Notices & Transparency
12. Training & Awareness
13. Compliance, Exceptions & Breaches of this Policy
14. Ownership, Review & Document Control

CHAPTER 1. PURPOSE, SCOPE & ROLES

What the policy covers, definitions, and how Northgate's controller vs processor role is determined per engagement; interaction with the Contract Playbook and POL-SEC-011.

This policy governs how Northgate Systems Ltd processes personal data, whether Northgate acts as controller (for its own employee, candidate, marketing and supplier data) or as processor (for personal data it handles on behalf of

customers through its products and services). It applies to all staff, contractors and business units, and to every contract, order form and data processing agreement (DPA) that involves personal data. It is the most-cited policy in Northgate's contract corpus and sets the mandatory positions that contract owners must hold when negotiating data protection terms.

Northgate's role must be determined for each engagement before terms are agreed, because the obligations differ. Northgate is a controller where it decides the purposes and means of processing (for example, its own CRM and marketing lists). Northgate is a processor where it processes personal data only on documented customer instructions (for example, data uploaded to the platform by a customer). Where roles are mixed or unclear, the DPO must be consulted before signature. The determination reached must be recorded and must be consistent with the DPA annex for that contract.

Key definitions

- Personal data, controller, processor, sub-processor and processing carry the meanings given in the UK GDPR and the Data Protection Act 2018.
- Restricted transfer means a transfer of personal data to a country outside the UK that requires an Art. 46 safeguard.
- DPA means the data processing agreement or annex that sets out the Art. 28 terms for an engagement.
- Special category data means the categories in UK GDPR, Art. 9 (health, biometric, and similar sensitive data).

This policy operates alongside the Contract Playbook, which carries the fallback negotiation positions, and POL-SEC-011 (Information Security), which governs the technical and organisational measures, hosting location and incident response referenced here. Where a data protection question also engages security controls, both policies apply and the stricter requirement governs.

CHAPTER 2. LAWFUL BASIS & MARKETING CONSENT

Establishing lawful basis (Art. 6) for each processing purpose, including legitimate-interest assessments; consent standards for marketing lists (opted-in individuals only) and PECR requirements for electronic marketing.

Every processing activity for which Northgate is controller must have a lawful basis identified under UK GDPR, Art. 6 before processing begins, and that basis must be recorded in the record of processing (see Chapter 10). The basis must fit the purpose: contractual necessity for account administration, legal obligation for statutory records, and legitimate interests for most business development and lead-handling. Consent is reserved for purposes where no other basis fits, principally direct electronic marketing.

Where legitimate interests are relied on, a legitimate-interests assessment (LIA) must be completed and retained, balancing Northgate's interest against the rights of the individuals concerned. This applies to lead-data sharing arrangements with partners: referral and channel lead flows must be aligned to a lawful basis (typically Art. 6(1)(f)) with the balancing test documented, as was done on the Bright Compass referral engagement. Partners must not be given personal data for purposes beyond those assessed.

Marketing consent and PECR

- Electronic marketing (email, SMS) may be sent only to individuals who have opted in, in line with PECR 2003 and Art. 6(1)(a); pre-ticked boxes and assumed consent are not acceptable.

- Marketing lists sourced from events and sponsorships must be limited to opted-in delegates only, as negotiated on the FutureOps Summit sponsorship; blanket delegate-list clauses must be amended before signature.
- Every marketing communication must carry a working unsubscribe mechanism, and opt-outs must be actioned promptly.
- The soft opt-in for existing customers may be used only within its statutory limits and never for third-party marketing.

Contract owners must resist counterparty clauses that would require Northgate to market to non-opted-in individuals or to share marketing data without a lawful basis, and must escalate to the DPO where a counterparty presses the point.

CHAPTER 3. PROCESSOR TERMS & DPA REQUIREMENTS

Mandatory Art. 28(3) terms in every DPA – instructions, confidentiality, security, audit rights, deletion/return; substituting full processor terms where a supplier offers a thin DPA.

Where Northgate acts as processor, or engages a supplier as processor, a written DPA containing the full set of Art. 28(3) terms is mandatory. No order form, subscription or supplier agreement that involves the processing of personal data may be signed without one. Processor obligations must be added to the DPA annex as a matter of course, as was done on the Cloudreach CRM subscription.

Mandatory Art. 28(3) terms

- Processing only on documented instructions of the controller, including for international transfers.
- A duty of confidentiality binding all personnel authorised to process the data.
- Appropriate technical and organisational security measures, consistent with POL-SEC-011.
- Sub-processor conditions and flow-down of equivalent obligations (see Chapter 4).
- Assistance to the controller with data-subject rights and with security, breach and DPIA obligations.
- Deletion or return of all personal data at the end of the engagement, and deletion of copies.
- Provision of information and submission to audits and inspections to demonstrate compliance (Art. 28(3)(h)).

Suppliers frequently offer a thin DPA that omits several of these terms. Where that occurs, contract owners must substitute Northgate's full processor terms rather than accept the deficient draft, as was done on the Bramley Payroll supplier agreement. Statutory references within DPAs must be kept current; on the Ashcombe amendment the references were refreshed for the Data (Use and Access) Act 2025 alongside UK GDPR, Art. 28. The equivalent EU GDPR, Art. 28 terms apply where an engagement is governed by EU law.

CHAPTER 4. SUB-PROCESSORS

Conditions for general written authorisation (Art. 28(2)), notification of new sub-processors, minimum objection window (30 days), and flow-down of processor obligations.

Northgate may appoint sub-processors only under a general written authorisation

given by the controller in the DPA, consistent with UK GDPR, Art. 28(2). Where Northgate is the controller engaging a processor, it grants general authorisation on the same terms and reserves the corresponding rights. Sub-processing without authorisation is prohibited.

Notification and objection

- Northgate must notify the controller in advance of any intended addition or replacement of a sub-processor, giving the controller a fair opportunity to object.
- The objection window is a minimum of 30 days; this is the standard position and must not be shortened below it.
- New sub-processors must be added on this basis, as was done when the analytics sub-processor was added on the Ashcombe engagement.
- A current list of sub-processors must be maintained and made available to controllers on request.

Northgate must impose on each sub-processor, by written contract, data protection obligations equivalent to those it owes the controller (flow-down), and remains fully liable to the controller for the sub-processor's performance. Where a customer or supplier requires notification of sub-outsourcing as a distinct obligation, that obligation must be honoured and recorded, as was added on the Vantoro order form. If a controller's reasonable objection cannot be resolved, the affected service may be suspended or terminated in accordance with the contract, and the DPO must be informed.

CHAPTER 5. INTERNATIONAL TRANSFERS & SAFEGUARDS

Restricted-transfer rules and approved safeguards (Art. 46): EU SCCs (2021/914), UK IDTA/addendum, adequacy decisions; when to prefer EEA/UK-only hosting instead of transfer mechanisms.

A restricted transfer of personal data outside the UK may proceed only where an approved safeguard under UK GDPR, Art. 46 is in place, or where an adequacy decision covers the destination. Transfers must never be arranged informally or as an afterthought; the transfer mechanism must be settled before data leaves the UK.

Approved safeguards

- The UK adequacy regulations, where the destination country benefits from a UK adequacy decision.
- The EU Standard Contractual Clauses (Commission Implementing Decision (EU) 2021/914) together with the UK International Data Transfer Addendum, or the standalone UK IDTA, for transfers requiring them.
- A transfer risk assessment where required, documented and retained with the contract.

Where a transfer mechanism can be avoided altogether, that is the preferred outcome. Northgate offers EEA-only and UK-only hosting options, and contract owners should propose data residency restrictions rather than rely on transfer clauses. This reflects settled corpus practice: payroll data residency was confirmed UK-only on the Bramley engagement, and data residency was restricted to EEA data centres only on the Ostrava cloud-hosting supplier agreement. Residency commitments must be consistent with POL-SEC-011 and reflected accurately in the DPA. Where onward transfers by a sub-processor are contemplated, the same safeguards must flow down.

CHAPTER 6. DATA RETENTION & DELETION

Storage-limitation (Art. 5(1)(e)) and minimisation (Art. 5(1)(c)) requirements; retention schedules aligned to platform deletion capabilities (e.g. 30-day purge) and end-of-contract deletion/return commitments.

Personal data must be kept only for as long as necessary for the purpose for which it was collected (storage limitation, Art. 5(1)(e)) and must be limited to what is adequate, relevant and necessary (data minimisation, Art. 5(1)(c)). Contract owners must not agree open-ended retention, and must not commit Northgate to retain data the platform is not designed to hold.

Retention schedules must be aligned to the platform's actual deletion capabilities. Northgate's standard is a 30-day purge cycle, and retention commitments in contracts must be aligned to that capability rather than to a shorter or unachievable window, as was done on the Bexley customer-paper DPA. Where a customer requests a bespoke schedule, it must be checked for technical feasibility before it is accepted.

End of engagement

- At the end of a processing engagement, Northgate will delete or return all personal data at the controller's choice, and delete existing copies, subject only to retention required by law.
- Deletion must extend to backups within the standard purge cycle and to any sub-processors.
- Any exit-assistance or data-export period agreed in the contract runs alongside, and does not displace, the deletion obligation.
- Deletion or return must be capable of being evidenced on request.

CHAPTER 7. SPECIAL CATEGORY & HIGH-RISK DATA; DPIAS

Handling of Art. 9 special-category data (health, etc.), scope exclusions to be confirmed in contract (no patient data / no student records), and when a DPIA (Art. 35) is required before signing an order form.

Special category data within UK GDPR, Art. 9 (including health and biometric data) attracts heightened protection and must not be processed without a valid Art. 9 condition in addition to an Art. 6 basis. Because Northgate's standard platform is not configured for such data, its processing is restricted and must be confirmed against the contract scope before any go-live.

Scope exclusions to confirm in the contract

- Where the counterparty operates in health or public sector, a scope note confirming no patient data is in scope should be included, as was done on the Bexley Community Health Trust mutual NDA.
- Where the counterparty is an education provider, a scope note confirming no student records are processed should be included, as was done on the Otterbourne College order form.
- These exclusions must be confirmed in writing and reflected in the DPA so that the platform is not used for data it is not designed to hold.

A data protection impact assessment (DPIA) under Art. 35 must be completed before signature wherever processing is likely to result in a high risk to individuals, in particular where special category or biometric data is involved. Contract owners must flag the requirement early: on the Ilex Biometrics NDA an

internal flag was added requiring a DPIA before any order form is signed. The DPIA must be reviewed by the DPO, and any residual high risk that cannot be mitigated must be referred to the DPO for a decision on whether to proceed or consult the regulator.

CHAPTER 8. PERSONAL DATA BREACH NOTIFICATION

Internal incident escalation and Art. 33 notification duties; contractual notification windows to customers (standard 48 hours – resist 12/24-hour demands) and coordination with POL-SEC-011 incident response.

A personal data breach is any breach of security leading to accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to personal data. Any suspected breach must be escalated internally without delay through the incident process in POL-SEC-011, so that it can be contained, assessed and, where required, notified.

Where Northgate is processor, it must notify the affected controller without undue delay after becoming aware of a breach. Where Northgate is controller and the breach is notifiable, it must notify the ICO within 72 hours under UK GDPR, Art. 33, and affected individuals where the threshold for doing so is met. Breach handling must be coordinated with POL-SEC-011 incident response so that legal, security and communications actions stay aligned.

Contractual notification windows

- Northgate's standard contractual notification commitment to customers is within 48 hours of becoming aware of a breach.
- Contract owners must resist demands for 12-hour or 24-hour notification, which are not operationally reliable; the 48-hour standard is to be retained.
- This position has held across the corpus: a customer 24-hour request was resolved back to 48 hours on the Brightwell DPA, and a 12-hour demand was extended to 48 hours on the Bexley customer-paper DPA.
- Notification obligations must be measured from when Northgate becomes aware, not from the moment of the incident itself.

CHAPTER 9. DATA SUBJECT RIGHTS & AUDIT COOPERATION

Assisting controllers with data-subject requests, audit and inspection rights under Art. 28(3)(h), and evidence/records to be maintained to demonstrate compliance.

Where Northgate is processor, it must assist the controller, by appropriate technical and organisational measures and insofar as possible, to respond to requests to exercise data-subject rights (access, rectification, erasure, restriction, portability and objection). Requests received directly by Northgate that relate to a controller's data must be routed to that controller promptly and must not be actioned unilaterally. Where Northgate is controller, it must handle requests it receives within the statutory timeframes.

Audit and inspection

- Northgate makes available the information necessary to demonstrate compliance with Art. 28 and allows for and contributes to audits and inspections under Art. 28(3)(h).

- The standard position is one audit per year, on reasonable prior notice, plus a for-cause audit following a substantiated incident.
- Audit rights framed as unlimited or on-demand must be narrowed to annual plus for-cause, as was done on the Brightwell DPA (once annually, 30 days' notice) and the Bexley customer-paper DPA.
- Regulator access and inspection rights, where a customer's regulator requires them, may be accepted where scoped appropriately.

Contract owners must ensure Northgate can meet its assistance obligations in practice, and must maintain the evidence and records needed to satisfy an audit without disproportionate effort, drawing on the records of processing described in Chapter 10.

CHAPTER 10. RECORDS OF PROCESSING & ACCOUNTABILITY

Maintaining the Art. 30 record of processing activities (controller and processor entries), the accountability principle (Art. 5(2)), and how processing records feed contract review and DPA negotiation.

Northgate maintains a record of processing activities under UK GDPR, Art. 30, with controller entries for the data it processes for its own purposes and processor entries for the data it processes on behalf of customers. The record must be kept current and must be available to the ICO on request. Maintaining it is a shared duty of the business units that own each processing activity, coordinated by the DPO.

The accountability principle (Art. 5(2)) requires Northgate not only to comply with the data protection principles but to be able to demonstrate that compliance. The record of processing, the legitimate-interests assessments, DPIAs, transfer documentation and DPA registers together form that evidence base.

Records that support contract review

- Processing records identify the sub-processors, hosting locations and retention periods that a DPA must reflect, and so feed directly into DPA negotiation.
- They provide the baseline against which counterparty DPA drafts are checked, including statutory-reference currency (for example the Data (Use and Access) Act 2025 update on the Ashcombe amendment).
- They support audit responses (Chapter 9) and breach assessment (Chapter 8) by identifying quickly what data is affected.
- Material changes to processing must be reflected in the record and, where relevant, in the affected contracts.

CHAPTER 11. PRIVACY NOTICES & TRANSPARENCY

Transparency obligations under Arts. 13-14: when privacy notices must be issued or updated, notice content standards, and layering for product, website and candidate/employee audiences.

Where Northgate is controller, it must provide clear privacy information to individuals under UK GDPR, Arts. 13 and 14: Art. 13 where data is collected from the individual, and Art. 14 where it is obtained from another source. Notices must be provided at or before the point of collection, or within the required period where data is obtained indirectly.

When notices must be issued or updated

- At launch of any new product feature, website form or campaign that collects personal data.
- When a new processing purpose, recipient or transfer is introduced, or a retention period changes.
- For distinct audiences, using notices tailored to product users, website visitors, and candidates and employees.
- When legislation or regulator guidance requires refreshed wording.

Notices must set out the controller identity and DPO contact, purposes and lawful bases, recipients and any sub-processors, international transfers and their safeguards, retention periods, and the individual's rights. Layering is encouraged: a short headline notice with a full notice behind it. Notice content must be consistent with the record of processing and with the lawful bases identified under Chapter 2; a notice must never describe processing that the record does not support.

CHAPTER 12. TRAINING & AWARENESS

Mandatory data-protection training at induction and annual refresh, role-specific training for teams handling personal data (support, sales ops, engineering), and completion tracking.

All staff must complete data protection training as part of induction, before they handle personal data, and an annual refresh thereafter. Training must cover the core principles, lawful bases, individual rights, the standard contract positions in this policy, and how to recognise and escalate a suspected personal data breach.

Role-specific training

- Support teams: handling data-subject requests, routing them to the correct controller, and avoiding over-collection.
- Sales and marketing operations: consent and PECR rules, opted-in marketing, and lawful-basis limits on lead-data sharing.
- Engineering: privacy by design and default, minimisation, retention and the 30-day purge, and secure handling consistent with POL-SEC-011.
- Contract owners: the mandatory DPA and negotiation positions in this policy and the Contract Playbook.

Completion must be tracked centrally. Managers are responsible for ensuring their teams are current, and the DPO reports on completion rates. Persistent non-completion is treated as a compliance matter under Chapter 13. Training is coordinated with the security awareness programme in POL-SEC-011 and with the HR onboarding process in POL-HR-003.

CHAPTER 13. COMPLIANCE, EXCEPTIONS & BREACHES OF THIS POLICY

Monitoring compliance with this policy, the process for requesting a documented exception (DPO approval required), and consequences of non-compliance including the disciplinary route for deliberate breaches.

Compliance with this policy is monitored by the DPO through contract review, audit responses, training completion and the record of processing. Contract

owners must apply the positions in this policy and must not agree data protection terms that fall below them without an approved exception.

Requesting an exception

- Any departure from a mandatory position in this policy (for example, a notification window shorter than 48 hours, a sub-processor objection window shorter than 30 days, or retention beyond the standard capability) requires a documented exception.
- Exceptions require DPO approval in advance, must record the rationale and any compensating controls, and must be time-limited and logged.
- Where an exception also engages security, POL-SEC-011 approval is required as well.
- Approved exceptions must be reflected accurately in the affected contract.

Non-compliance may expose Northgate and individuals to regulatory action and harm. Inadvertent breaches of this policy must be reported to the DPO so they can be corrected. Deliberate breaches, or repeated failures to follow it, are handled through the disciplinary route in POL-HR-003, up to and including dismissal for serious cases, without prejudice to any regulatory or legal consequences.

CHAPTER 14. OWNERSHIP, REVIEW & DOCUMENT CONTROL

Policy owner (DPO), annual review cycle and triggers for out-of-cycle review (new legislation, regulator guidance, incident learnings), version history and related documents (Contract Playbook, POL-SEC-011).

This policy is owned by the Data Protection Officer, who is responsible for its content, for approving exceptions, and for advising the business on its application. Questions of interpretation and requests for guidance on specific contracts should be directed to the DPO.

Policy ID	: POL-PRIV-001
Owner	: Northgate Systems Ltd – Legal / DPO
Review cycle	: Annual
Related documents	: Contract Playbook; POL-SEC-011; POL-HR-003; POL-FIN-007; POL-LGL-002

Triggers for out-of-cycle review

- New or amended legislation affecting data protection (for example, the Data (Use and Access) Act 2025).
- New ICO or regulator guidance that changes expected practice.
- Learnings from a personal data breach or incident.
- A pattern of exception requests indicating a standard position needs revisiting.

All changes must be version-controlled with a dated version history recording the nature of each change and its author. The current version supersedes all earlier versions. Material changes must be communicated to affected teams and, where they change a mandatory contract position, reflected in the Contract Playbook so that the two documents remain consistent.

=====